

Task 3: Post-Implementation Discussion

Yummy Pretzel Co. Phishing Campaign and Security Improvement Project

A. Describe the policies adopted as a result of your implemented project.

Following the implementation of the phishing security solution, Yummy Pretzel Co. adopted several cybersecurity policies designed to establish consistent requirements for email security, incident response, authentication, endpoint protection, and employee reporting. The policies were developed based on the risks identified during the phishing incident and the security controls implemented during the project.

The first policy adopted was an Email and Phishing Security Policy. This policy establishes requirements for identifying, reporting, and handling suspicious emails. Employees are prohibited from opening unexpected attachments, clicking suspicious links, or providing credentials in response to unsolicited email requests. Employees are required to report suspected phishing messages to the IT security team. Microsoft Defender for Office 365 provides technical controls that complement these requirements by detecting and responding to malicious links, attachments, and other email-based threats (Microsoft, n.d.-c).

The organization also adopted an Incident Response Policy. This policy establishes procedures for identifying, containing, investigating, eradicating, and recovering from cybersecurity incidents. The policy requires compromised endpoints to be isolated when malware is detected and requires security personnel to preserve relevant logs and other evidence before completing remediation. These practices align with the incident-response concepts described by the National Institute of Standards and Technology (NIST, 2025).

An Identity and Access Management Policy was also adopted. The policy requires multifactor authentication for organizational accounts and establishes access requirements based on business need. Microsoft Entra ID supports multifactor authentication and Conditional Access capabilities that help reduce the risk of compromised credentials being used to access organizational resources (Microsoft, n.d.-a).

Finally, Yummy Pretzel Co. adopted a Security Awareness and Phishing Simulation Policy requiring employees to participate in recurring security awareness training and simulated phishing exercises. KnowBe4 is used to conduct training and phishing simulations, enabling the organization to measure employee susceptibility to phishing attempts over time (KnowBe4, 2026).

A1. Summarize how the solution improves cybersecurity decision-making.

The implemented solution improves cybersecurity decision-making by providing the security team with more timely and actionable information. Before implementation, a suspicious email could remain undetected unless an employee recognized and reported it. Following implementation, security technologies automatically analyze email messages, monitor endpoints, collect authentication information, and provide security alerts.

This allows IT and security personnel to make decisions using information from multiple sources rather than relying exclusively on employee reports. For example, Defender for Office 365 can identify malicious email characteristics, while Defender for Endpoint provides endpoint telemetry and investigation information. Security personnel can correlate these events to determine whether a phishing email resulted in an endpoint compromise.

The organization can also use phishing simulation results to identify departments or groups that require additional training. This changes cybersecurity decision-making from a primarily reactive process to a data-driven, continuous-improvement process.

B. Describe how your solution meets the following cybersecurity assurance criteria.

Promotes automation in cybersecurity

The solution promotes automation by using security technologies to identify and respond to threats without requiring every action to be performed manually by an employee or security analyst.

Microsoft Defender for Office 365 automatically analyzes email messages, links, and attachments for potentially malicious activity. Defender for Endpoint provides endpoint detection capabilities and supports response actions such as device isolation (Microsoft, n.d.-b; Microsoft, n.d.-c).

Automation reduces the time between detection and response. If an endpoint demonstrates indicators of malware activity, the security team can isolate the device while the investigation is performed. This reduces the opportunity for an attacker to move laterally or access additional organizational resources.

Improves and modernizes security

The solution modernizes Yummy Pretzel Co.'s security environment by replacing a primarily employee-dependent phishing defense with multiple layers of technical and administrative protection.

The implemented environment combines email security, endpoint detection and response, multifactor authentication, S/MIME, security awareness training, and phishing simulations.

This defense-in-depth approach means that failure of one control does not necessarily result in a successful compromise. For example, if an employee opens a malicious email, endpoint detection may detect the malware. If an attacker obtains credentials, MFA provides another security barrier.

Implements industry-standard security tools and infrastructure

The project implements commercially available security technologies commonly used to protect enterprise environments. Microsoft Defender for Office 365 provides email security; Microsoft Defender for Endpoint provides endpoint security; Microsoft Entra ID supports identity and access controls; DigiCert provides S/MIME certificates; and KnowBe4 provides security awareness and phishing simulation capabilities.

The security architecture also aligns with industry-standard cybersecurity practices described by NIST. The NIST Cybersecurity Framework 2.0 provides a structure for managing cybersecurity risk, while NIST SP 800-53 provides a catalog of security and privacy controls (National Institute of Standards and Technology, 2020; Pascoe et al., 2024).

C. Explain how your solution addresses the following data collection and implementation elements.

Collects digital evidence, including data for analysis or forensics

The post-implementation environment generates significantly more security data than the original environment.

- Email security alerts
- Malicious attachment detections
- Malicious URL detections
- Endpoint detection alerts

- Endpoint isolation events
- Malware detection information
- Authentication logs
- MFA events
- Conditional Access events
- Phishing simulation results
- Security awareness training completion
- Incident response tickets
- Investigation notes
- Malware remediation results

These records provide evidence that can be used during security investigations. For example, if an employee opens a malicious attachment, the security team can investigate the original email, identify the affected endpoint, examine endpoint activity, review authentication activity, determine whether additional systems were accessed, and document the response.

Maintaining these records also improves the organization's ability to reconstruct the sequence of events during an incident.

Implements confidentiality, integrity, and availability

The solution supports all three components of the CIA triad.

Confidentiality is improved through S/MIME encryption, multifactor authentication, access controls, and endpoint security. These controls help prevent unauthorized individuals from accessing sensitive company and employee information.

Integrity is improved through digital signatures, endpoint monitoring, malware detection, and security logging. Digital signatures can help recipients verify the authenticity and integrity of signed email messages.

Availability is improved through automated endpoint isolation, malware remediation, and incident response procedures. Rapidly isolating an infected computer helps prevent malware from disrupting additional systems and allows the affected endpoint to be restored more quickly.

D. Explain how your solution investigates and mitigates cybersecurity incidents or crimes within the environment where the solution was implemented.

Detection: A phishing event is identified through Microsoft Defender for Office 365, an employee report, or another security alert.

Triage: IT and security personnel determine whether the email is malicious and identify affected users and devices.

Containment: If malware is detected on an endpoint, the endpoint is isolated from the organization's network. This prevents the compromised system from communicating with other systems during the investigation.

Investigation: Analysts examine email records, endpoint telemetry, authentication activity, network connections, and other available security logs. The purpose is to determine the scope and impact of the incident.

Eradication: Malware and malicious artifacts are removed, compromised credentials are reset, and affected accounts or systems are restored to a trusted state.

Recovery: The endpoint is returned to production after security personnel verify that malicious activity has been removed.

Lessons Learned: The organization reviews the incident to determine whether additional technical controls, employee training, or procedures are necessary.

This approach is consistent with NIST's incident-response recommendations and supports a repeatable response process (National Institute of Standards and Technology, 2025).

E. Describe the cybersecurity plans, standards, or procedures that were developed for the solution.

Yummy Pretzel Co. developed a set of cybersecurity procedures to support the implemented phishing-protection solution and establish consistent security practices for employees and IT and security personnel. These procedures define how the organization should prevent, identify, contain, investigate, and recover from phishing-related security incidents. The procedures also support the organization's incident management and security awareness practices.

1. Phishing Email Reporting Procedure

The phishing email reporting procedure establishes how employees should respond when they receive a suspicious email. Employees are instructed not to click links, open unexpected attachments, reply to the sender, or delete the original message before reporting it. Instead, employees should use the designated reporting process to notify the IT security team. Security personnel review the reported message to determine whether it is malicious and whether other employees received the same email. If additional users received the message, security personnel can search for and remove related messages from employee mailboxes. This procedure helps the organization identify phishing campaigns more quickly and reduces the likelihood that additional employees will interact with the malicious message.

2. Malware Detection and Endpoint Isolation Procedure

The malware detection and endpoint isolation procedure establishes the actions that security personnel should take when Microsoft Defender for Endpoint identifies potentially malicious activity. When a device demonstrates indicators of compromise, security personnel determine whether the endpoint should be isolated from the network. Isolation prevents the potentially compromised device from communicating with other systems while allowing security personnel to investigate the incident. Before the endpoint is returned to production, the malware must be removed, the source of the compromise must be investigated, and the system must be verified as secure. This procedure reduces the opportunity for malware to spread to additional systems.

3. Incident Investigation Procedure

The incident investigation procedure establishes a consistent process for investigating suspected phishing and malware incidents. Security personnel collect relevant information, including email messages, authentication records, endpoint alerts, network activity, and other available security logs. Investigators determine the incident's initial source, identify affected systems or accounts, and assess whether sensitive information may have been accessed or compromised. The investigation findings are documented and used to determine appropriate containment, remediation, and recovery actions.

4. Compromised Account Response Procedure

The compromised account response procedure outlines the actions required when an employee account is suspected to be compromised. Security personnel review authentication activity, identify unusual login attempts, and determine whether unauthorized access occurred. Depending on the circumstances, the account may be temporarily disabled, the user's credentials may be reset, active sessions may be revoked, and additional authentication controls may be applied. The security team also reviews related activity to determine whether the compromised account was

used to access other organizational resources. These actions help prevent attackers from maintaining unauthorized access.

5. Security Awareness Training Procedure

The security awareness training procedure establishes requirements for employee cybersecurity education. Employees receive training on recognizing phishing messages, identifying suspicious links and attachments, protecting credentials, using MFA, and reporting suspected security incidents. Training completion is tracked to identify employees or departments that require additional instruction. The procedure supports a continuous security awareness program rather than treating employee training as a one-time activity.

6. Phishing Simulation Procedure

The phishing simulation procedure establishes how Yummy Pretzel Co. can conduct controlled phishing simulations to measure employee susceptibility to social engineering attacks.

Simulations are designed to resemble realistic phishing attempts without placing employees or organizational systems at risk. Results can be used to identify trends such as high click rates or low reporting rates. Employees who demonstrate difficulty identifying simulated phishing messages can receive additional training. This procedure allows the organization to measure whether security awareness training is improving employee behavior over time.

7. S/MIME Certificate Management Procedure

The S/MIME certificate management procedure establishes how email encryption certificates are issued, deployed, maintained, renewed, and revoked. IT personnel are responsible for ensuring that certificates are assigned to the appropriate users and remain valid. Lost, compromised, or expired certificates must be addressed in accordance with the organization's certificate

management process. Proper certificate management helps maintain the integrity and confidentiality of protected email communications.

8. Post-Incident Review Procedure

The post-incident review procedure establishes a formal process for evaluating security incidents after containment and recovery are complete. Security personnel review the incident timeline, security controls involved, response actions, communication, and recovery activities. The team identifies what worked effectively and what could be improved. Lessons learned are documented and may result in changes to security procedures, employee training, technical controls, or monitoring practices. This procedure supports the continuous improvement of the organization's cybersecurity program.

Together, these procedures establish a repeatable security process that spans prevention and employee awareness through detection, containment, investigation, recovery, and continuous improvement. The procedures also provide employees and security personnel with clearly defined responsibilities, reducing uncertainty during a security incident.

E1. Explain how the solution is aligned with cybersecurity initiatives or regulatory compliance.

The solution aligns with recognized cybersecurity standards and initiatives, particularly the NIST Cybersecurity Framework 2.0 and NIST SP 800-53.

The NIST Cybersecurity Framework 2.0 provides a structure for identifying, protecting, detecting, responding to, and recovering from cybersecurity risks (Pascoe et al., 2024).

The project also supports security controls for access control, audit and accountability, incident response, system and communications protection, and awareness and training, as described in NIST SP 800-53 (National Institute of Standards and Technology, 2020).

Because Yummy Pretzel Co. is a fictional commercial organization rather than a healthcare, education, or payment-processing organization, HIPAA and FERPA are not assumed to be directly applicable. However, protecting employee PII and business information remains an organizational security requirement.

E2. Summarize the applications, tools, installation guides, or user guides developed.

Microsoft Defender for Office 365 Configuration Documentation

Provides instructions for configuring email security capabilities for identifying and responding to phishing threats, including malicious URL detection, attachment analysis, anti-phishing controls, and email security policies.

Microsoft Entra ID and MFA Configuration Documentation

Provides instructions for configuring identity and authentication controls and monitoring authentication activity for suspicious behavior.

S/MIME Certificate Deployment Instructions

Explain how email certificates are issued and configured for employees who require secure email communication, including certificate installation, use, renewal, and replacement.

KnowBe4 Employee Training Instructions

Guide employees through security awareness training covering phishing recognition, indicators of suspicious email, safe handling of links and attachments, credential protection, and incident reporting.

Phishing Simulation Procedures

Provide IT and security personnel with instructions for planning, distributing, monitoring, and evaluating controlled phishing exercises.

Phishing Email Reporting Instructions

Explain how employees should identify and report suspicious messages without interacting with potentially malicious content.

Endpoint Isolation Procedures

Provide security personnel with instructions for responding when an endpoint demonstrates signs of malware or compromise, including isolation and return-to-production criteria.

Incident Response Documentation

Provides a structured process for identification, analysis, containment, eradication, recovery, and communication during suspected security incidents.

Post-Incident Review Documentation

Provides a structured format for documenting the incident timeline, root cause, affected systems, response actions, lessons learned, and recommended improvements.

Collectively, these resources provide Yummy Pretzel Co. with both technical and employee-facing guidance. The technical documentation supports configuration and maintenance of security controls, while the employee guides establish consistent security behaviors. Together, they improve the organization's ability to operate and maintain the implemented solution after the initial deployment.

F. Discuss the post-implementation environment.

After implementation, Yummy Pretzel Co. operates a layered cybersecurity environment designed to protect employees, email communications, endpoints, identities, and organizational information from phishing-related threats. The environment combines preventive, detective, and responsive security controls rather than relying on a single security technology.

The first layer of protection is Microsoft Defender for Office 365 Plan 2, which evaluates incoming email for indicators of phishing, malicious links, and harmful attachments. Messages identified as malicious can be blocked or routed for security investigation before employees interact with them. This provides an initial security boundary between external email threats and the organization's users.

Messages that are permitted to reach employees are protected by additional controls at the endpoint and identity levels. Microsoft Defender for Endpoint monitors employee devices for malicious activity and indicators of compromise. If malware or other suspicious activity is detected, security personnel can investigate the alert and isolate the affected endpoint to reduce the possibility of further compromise or lateral movement.

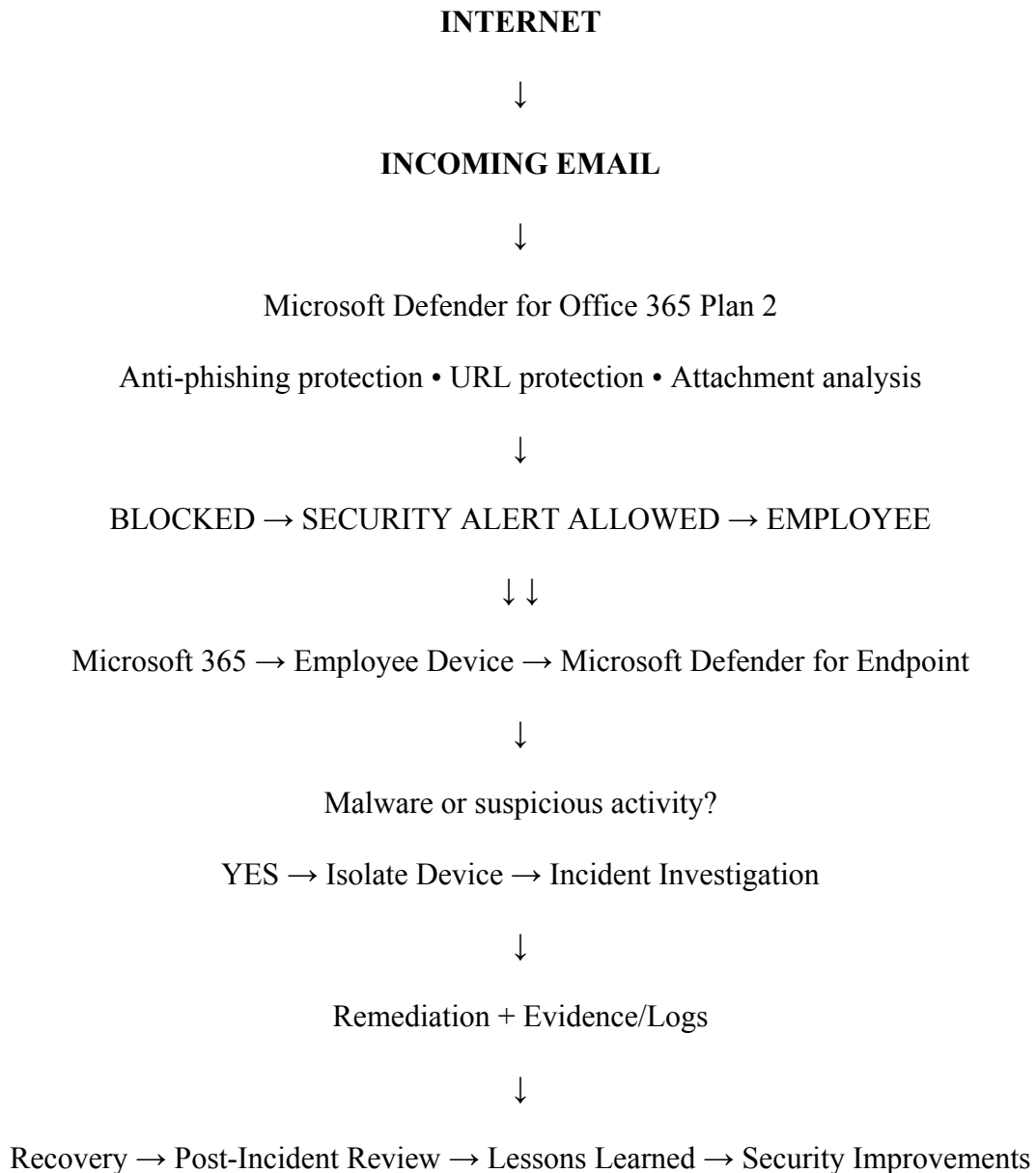
Microsoft Entra ID and MFA provide an additional layer of identity protection. Even if an attacker obtains an employee's password through phishing, MFA still requires an additional authentication step. Authentication activity can also be reviewed to identify unusual or potentially unauthorized login attempts.

S/MIME protects appropriate email communications by supporting encryption and digital signatures. Encryption helps protect the confidentiality of email communications, while digital signatures can help recipients verify the authenticity and integrity of messages.

Employee security awareness training and phishing simulations provide a human-centered layer of protection. Employees are trained to identify suspicious messages and are given a defined

process for reporting them. Phishing simulations allow the organization to measure employee behavior and determine where additional training may be necessary.

The post-implementation environment, therefore, operates as a defense-in-depth architecture.



The architecture creates multiple opportunities to stop an attack. For example, a phishing email may be blocked by Microsoft Defender for Office 365 before reaching an employee. If the message reaches an employee and the user interacts with malicious content, Microsoft Defender for Endpoint can provide another opportunity to detect the resulting malware activity. If an attacker obtains user credentials, MFA provides an additional identity security control. If an incident occurs, the incident response procedures provide a structured process for containment, investigation, remediation, and recovery.

The post-implementation environment also changes how security personnel perform their daily responsibilities. Instead of relying primarily on employees to recognize and report phishing attempts, security personnel now have additional technical data and automated security controls available for detection and response. Security alerts, endpoint telemetry, authentication events, training results, and phishing simulation results can be reviewed to identify trends and improve security decisions.

The environment also supports continuous improvement. Information collected from security incidents and employee activities can be used to identify weaknesses, adjust security controls, improve training, and update procedures. As a result, the implemented solution is not a one-time security improvement but an ongoing cybersecurity process.

F1. Describe how the solution improved the security posture and efficiency of the organization.

The security solution improved Yummy Pretzel Co.'s security posture by creating multiple defensive layers between an attacker and sensitive organizational information.

Before implementation, a successful phishing email could depend heavily on employee recognition and reporting. Following implementation, technical controls analyze email, monitor endpoints, protect identities, and provide automated response capabilities.

The solution also improves efficiency because security personnel no longer need to manually investigate every suspicious email from the beginning. Automated detection and alerting prioritize potentially malicious events for investigation.

Employee training further improves efficiency by reducing avoidable phishing interactions and improving employee reporting behavior.

F2. Analyze the newly collected data, including how the solution will affect business processes.

Following implementation, Yummy Pretzel Co. can collect security data that provides measurable information about employee behavior, security control effectiveness, incident response, and recovery. These metrics allow management and security personnel to evaluate whether the implemented solution is achieving its intended objectives.

Data / Security Metric	Business / Security Value
Phishing click rate	Measures employee susceptibility to phishing attacks and identifies areas where additional security awareness training may be necessary.
Phishing reporting rate	Measures how frequently employees recognize and report suspected phishing attempts to the security team.
Malicious email detections	Measures the volume of potentially malicious messages identified by email security controls and provides information about the types of threats targeting the organization.
Malware detections	Identifies endpoints exhibiting potentially malicious activity and helps security personnel determine whether additional investigation or containment is required.
Endpoint isolation events	Measures how frequently potentially compromised endpoints require isolation and provides insight into the organization's ability to contain threats.
MFA failures	Identifies potentially suspicious authentication

	activity and may indicate attempted unauthorized access or compromised credentials.
Training completion	Measures employee participation in required cybersecurity awareness training and helps management identify departments or users requiring additional attention.
Incident response time	Measures how quickly the security team identifies and begins responding to security incidents.
Mean time to containment (MTTC)	Measures how effectively and quickly the organization limits the spread or impact of a security incident after detection.
Mean time to recovery (MTTR)	Measures how efficiently affected systems are restored to normal operations following a security incident.

The newly collected data affects business processes by allowing security decisions to be based on measurable evidence rather than assumptions. For example, a high phishing-click rate in a particular department may indicate that employees there require additional training. Management can use this information to target training resources to employees who demonstrate the greatest need, rather than applying identical additional training across the entire organization.

The phishing reporting rate provides a different perspective. A low click rate is beneficial, but it does not necessarily mean employees are actively identifying threats. Employees may simply be ignoring suspicious messages without reporting them. A high reporting rate can demonstrate that employees are participating in the organization's security process and providing information that allows the security team to investigate potential threats.

Malicious email and malware detection data can also affect technical operations. An increase in malicious email detections may indicate a change in the organization's threat environment and could require security personnel to review email protection policies. Similarly, an increase in malware detections or endpoint isolation events may indicate the need for additional investigation, endpoint controls, or employee training.

MFA failure data can assist with identifying suspicious authentication behavior. For example, repeated authentication failures involving an employee account could indicate a potential credential attack. Security personnel can investigate the account and determine whether additional protective measures are necessary.

Incident response time, mean time to containment, and mean time to recovery provide management with measurements of the security team's operational effectiveness. If incident response time increases, management may need to evaluate staffing, alert prioritization, procedures, or automation. If the mean time to containment decreases, this can demonstrate that the organization's detection and response capabilities are improving. Similarly, a reduction in mean time to recovery can indicate that recovery procedures are becoming more efficient.

These metrics can also influence broader business processes. Security leaders can use the collected information to prioritize training, allocate security resources, adjust security policies, improve technical controls, and identify areas requiring additional investment. The metrics can also be compared over time to determine whether the implemented solution is producing sustained improvements.

For example, if Yummy Pretzel Co. observes that the phishing click rate decreases while the phishing reporting rate increases, the organization has evidence that employees are becoming more capable of identifying and reporting phishing attempts. If the organization also observes faster containment and recovery times, management can determine that the combination of employee training, technical controls, and incident response procedures is improving the organization's overall security posture.

Overall, the newly collected data creates a feedback loop for cybersecurity decision-making. Security data is analyzed to identify weaknesses; the organization makes security or business

decisions; controls or training are improved; and the results are measured again. This process allows Yummy Pretzel Co. to continuously evaluate the effectiveness of its cybersecurity program while minimizing disruption to business operations.

F3. Describe the summative evaluation plan from Task 2, including the test results and a plan of action to correct any weaknesses or deficiencies.

The summative evaluation tested whether the implemented controls successfully reduced the risks identified during Task 2. The following results represent the fictional post-implementation testing used to evaluate the solution

Test	Expected Result	Simulated Result	Status
Malicious attachment test	Attachment blocked/quarantined	Attachment blocked	Pass
Malicious URL test	URL blocked or warning generated	URL blocked	Pass
Malware execution test	Endpoint detects malware	Detection generated	Pass
Endpoint isolation test	Compromised endpoint isolated	Device isolated	Pass
MFA bypass attempt	Unauthorized login prevented	Login prevented	Pass
S/MIME test	Message encrypted/signed successfully	Successful	Pass
Phishing simulation	Reduced employee click rate	4% click rate	Pass
Phishing reporting test	Employees report simulated phishing	87% reporting rate	Pass
Incident response test	Incident contained and documented	Successfully completed	Pass

The simulated phishing campaign initially produced a 32% click rate during the baseline assessment. After security awareness training and implementation of the security controls, the follow-up simulation resulted in a 4% click rate. This represents a significant reduction in employee susceptibility to phishing.

Therefore, the project met its minimum acceptance criteria. However, the 4% click rate demonstrates that phishing remains a continuing risk. The organization should continue quarterly simulations and targeted training.

F4. Discuss post-implementation risks, including likelihood, organizational impact, and mitigation.

Post-Implementation Risk	Likelihood	Impact	Mitigation
Employee falls for a sophisticated phishing attack	Medium	High	Recurring phishing simulations, targeted training, MFA, and email security
New malware bypasses existing detection	Medium	High	Continuous Defender updates, endpoint monitoring, threat intelligence, and security testing
Compromised credentials are used against cloud services	Medium	High	MFA, Conditional Access, account monitoring, and rapid credential reset
S/MIME certificate expires	Low	Medium	Certificate inventory, automated renewal reminders, and certificate management procedures
Security alerts are not reviewed promptly	Medium	High	Defined alert ownership, escalation procedures, and monitoring metrics

The highest-impact risk is a sophisticated phishing attack that successfully bypasses automated email security and convinces an employee to interact with the attacker. The organization cannot eliminate this risk. Instead, it must maintain defense-in-depth controls and continuously improve its ability to detect and respond to new attacks.

F5. Explain how the security solution meets each of the project stakeholders' needs.

Stakeholder	Need	How the Solution Meets the Need
IT	Reliable security monitoring, incident response, and manageable security controls.	Defender for Office 365, Defender for Endpoint, Entra ID, and security information provide IT personnel with additional visibility and response capabilities.
Networking	Prevent compromised devices from communicating with other organizational systems.	Endpoint isolation allows compromised systems to be contained while networking personnel assist with investigation and recovery.
Human Resources	Protect employee personal information and improve employee security awareness.	Encryption, MFA, phishing protection, and security awareness training reduce the likelihood that employee PII will be exposed through phishing attacks.
Finance	Protect financial information and reduce the possibility of fraudulent transactions resulting from compromised accounts.	MFA, phishing protection, and employee awareness training provide additional protection against credential theft and business email compromise.
Marketing	Protect company communications and marketing information from unauthorized access.	Email filtering, S/MIME, endpoint protection, and identity security reduce the risk of unauthorized access.
Sales	Protect customer communications and business information.	Email security and encryption protect communications, while phishing training helps employees identify fraudulent messages.
Legal	Protect sensitive business information and maintain evidence during security incidents.	Logging, incident documentation, email records, endpoint telemetry, and established response procedures provide information that can support investigations.

Operations	Maintain business continuity while minimizing disruption caused by cybersecurity incidents.	Automated detection and endpoint isolation allow compromised devices to be contained while limiting the impact on the rest of the organization.
External Security Consultant/Technology Support	Clearly defined technical requirements and configuration standards.	The project established documented security requirements, implementation procedures, configuration documentation, and testing criteria that provide external technical personnel with a consistent basis for supporting the environment.

G. Describe the post-implementation maintenance plan for the solution.

Yummy Pretzel Co. will use a combination of short-term and long-term maintenance activities.

Daily

IT/security personnel will:

- Review security alerts.
- Review malware detections.
- Investigate suspicious authentication events.
- Monitor isolated endpoints.
- Respond to reported phishing emails.

Weekly

Security personnel will:

- Review incident tickets.

- Examine recurring phishing indicators.
- Verify that security controls remain operational.
- Review endpoint protection status.

Monthly

The Organization will:

- Review security metrics.
- Review employee phishing reports.
- Review MFA and authentication trends.
- Verify S/MIME certificate status.
- Review security awareness completion.

Quarterly

Yummy Pretzel Co. will:

- Conduct a simulated phishing campaign.
- Provide targeted employee training.
- Review incident response procedures.
- Conduct security-control testing.
- Review post-implementation risks.

Annually

The organization will:

- Review and update security policies.
- Reassess cybersecurity risks.
- Review vendor technologies and licensing.
- Conduct a comprehensive security assessment.
- Update the security architecture as necessary.

This maintenance strategy ensures that the solution does not become a one-time implementation. Cybersecurity controls must continuously evolve as attackers develop new techniques.

H. Original Artifact: Post-Implementation Phishing Incident Response Procedure

Yummy Pretzel Co. – Phishing Incident Response Procedure

Purpose: Establish a standardized process for identifying, containing, investigating, eradicating, and recovering from phishing-related security incidents.

Step 1 – Detection

A phishing event is identified through Microsoft Defender for Office 365, an employee report, or another security alert.

Step 2 – Triage

IT and security personnel determine the sender identity, recipients, message contents, attachments, URLs, indicators of compromise, and potentially affected users.

Step 3 – Containment

If malware is suspected or detected, isolate the affected endpoint, block malicious URLs or domains, quarantine related email, and disable or reset compromised credentials when necessary.

Step 4 – Investigation

Security personnel review email logs, endpoint telemetry, authentication logs, MFA activity, network connections, malware indicators, and user activity.

Step 5 – Eradication

Security personnel remove malware and malicious files, reset compromised credentials, apply required security updates, and verify endpoint security status.

Step 6 – Recovery

The endpoint may return to production after security personnel verify that malware has been removed, security controls are operational, required credentials have been secured, and there are no ongoing indicators of compromise.

Step 7 – Lessons Learned

The incident is documented and reviewed. The security team determines whether additional employee training is required, email filtering rules should be modified, security controls should be adjusted, policies or procedures should be updated, or additional testing is necessary.

Incident Closure Criteria

An incident may be closed when:

- The threat has been contained.
- Malware has been removed.
- Compromised credentials have been secured.
- Relevant evidence has been preserved.

- The affected system has been validated.
- The incident has been documented.
- Required corrective actions have been assigned.

I. References

Cybersecurity and Infrastructure Security Agency. (2024, September 25). CISA warns of hurricane-related scams. <https://www.cisa.gov/news-events/alerts/2024/09/25/cisa-warns-hurricane-related-scams>

Dawkins, S., & Jacobs, J. (2023). NIST Phish Scale user guide (NIST Technical Note 2276). National Institute of Standards and Technology. <https://doi.org/10.6028/NIST.TN.2276>

DigiCert. (n.d.). Buy secure email (S/MIME) certificates. Retrieved August 18, 2026, from <https://www.digicert.com/tls-ssl/secure-email-smime-certificates>

DigiCert. (n.d.). Compare secure email (S/MIME) certificates. Retrieved August 18, 2026, from <https://www.digicert.com/tls-ssl/compare-secure-email-smime-certificates>

KnowBe4. (2026). Security awareness training pricing. Retrieved August 18, 2026, from <https://www.knowbe4.com/products/security-awareness-training/pricing>

Microsoft. (2025). Microsoft Digital Defense Report 2025. <https://www.microsoft.com/en-us/corporate-responsibility/cybersecurity/microsoft-digital-defense-report-2025>

Microsoft. (n.d.-a). Microsoft Entra ID. Retrieved August 18, 2026, from <https://www.microsoft.com/en-us/security/business/identity-access/microsoft-entra-id>

Microsoft. (n.d.-b). Microsoft Defender for Endpoint. Microsoft Learn. Retrieved August 18, 2026, from <https://learn.microsoft.com/en-us/defender-endpoint/supported-capabilities-by-platform>

Microsoft. (n.d.-c). Microsoft Defender for Office 365. Retrieved August 18, 2026, from <https://www.microsoft.com/en-us/security/business/siem-and-xdr/microsoft-defender-office-365>

National Institute of Standards and Technology. (2020). Security and privacy controls for information systems and organizations (NIST Special Publication 800-53 Rev. 5). <https://doi.org/10.6028/NIST.SP.800-53r5>

National Institute of Standards and Technology. (2025, April 3). NIST revises SP 800-61: Incident response recommendations and considerations for cybersecurity risk management. <https://www.nist.gov/news-events/news/2025/04/nist-revises-sp-800-61-incident-response-recommendations-and-considerations>

Pascoe, C., Quinn, S., & Scarfone, K. (2024). The NIST Cybersecurity Framework (CSF) 2.0 (NIST Cybersecurity White Paper 29). National Institute of Standards and Technology.

<https://doi.org/10.6028/NIST.CSWP.29>

Verizon. (2025). 2025 Data breach investigations report. <https://www.verizon.com/about/news/2025-data-breach-investigations-report-emea>